

Actividad No. 5

Cuadro de análisis empresa HealthSoft

Problema identificado	Control aplicable	Justificación del control	Medida correctiva recomendada
Servidor principal que se encuentra sin cerradura ni control de acceso	A.7.1 – Áreas seguras físicas	Lo que busca este control es prevenir el acceso físico que no este autorizado a instalaciones en donde exista información sensible o infraestructura delicada	Reubicar el servidor en una sala cerrada con cerradura electrónica y acceso solo para personal autorizado
Acceso libre al edificio sin registro de visitantes	A.7.2 – Control físico de entrada	Este control exige limitar y registrar el acceso(logs) a instalaciones donde se maneja información o equipos sensibles	Implementar un sistema de ingreso o recepción, donde se registre la entrada de cada persona y que para ingresar se tenga algún tipo de credenciales
No existen cámaras de vigilancia ni registro visual	A.7.4 – Vigilancia física	Las organizaciones deben implementar los siguientes tres pasos para detectar e impedir el acceso no autorizado a las instalaciones que albergan activos de información críticos y evitar que se vean comprometidos. <i>Implementar un sistema de monitoreo por video para vigilar la situación</i> <i>Instalación de detectores para activar una alarma</i> <i>Configuración de Alarmas para Todos los Locales Internos</i>	Instalar cámaras CCTV en puntos de entrada y áreas críticas, con almacenamiento de grabaciones mínimo 30 días
Estaciones de trabajo	A.6.2 – Términos y	Describe la necesidad de que las organizaciones	Configurar bloqueo automático de

Problema identificado	Control aplicable	Justificación del control	Medida correctiva recomendada
desbloqueadas durante pausas	condiciones de empleo	definan las responsabilidades de seguridad de la información de los empleados en sus términos de empleo, incluidos los acuerdos de confidencialidad, las obligaciones legales y las consecuencias de las violaciones de seguridad	pantalla después de cierto tiempo de inactividad y la vez se tiene que concientizar sobre el bloqueo manual
Red Wi-Fi interna mal configurada y sin autenticación fuerte	A.5.14 – Seguridad de redes	Este control exige que las redes estén protegidas contra accesos no autorizados, especialmente inalámbricas.	Cambiar contraseñas regularmente y segmentar la red, como también implementar algún tipo de autenticación para poder acceder al Wi-Fi
No se realizan copias de seguridad externas	A.5.30 – Respaldo de información	Garantiza que las organizaciones mantengan la preparación para la continuidad del negocio identificando actividades críticas, implementando planes de respuesta estructurados y probándolos y actualizándolos periódicamente para garantizar la resiliencia durante las interrupciones	Automatizar backups periódicos en la nube y probar siempre los backups para comprobar que verdaderamente funcionan
Laptops del equipo sin anclaje físico	A.7.8 – Equipos de usuario	Se centra en proteger los equipos contra amenazas físicas, ambientales y de acceso no autorizado mediante ubicación segura, monitoreo ambiental y controles de seguridad	Reubicar el equipo en áreas vigiladas para evitar robo. Uso de contraseña y autenticación multifactor para poder acceder a la laptop
No hay protección contra incendios	A.7.5 – Protección contra amenazas	Exige a las organizaciones evaluar y mitigar los riesgos de amenazas físicas y ambientales, como desastres naturales e	Instalar detectores de humo y extintores portátiles cerca de los equipos o puntos críticos. Capacitar al

Problema identificado	Control aplicable	Justificación del control	Medida correctiva recomendada
	físicas y ambientales	incidentes inducidos por el hombre, a través de una evaluación proactiva de riesgos, controles de seguridad y monitoreo continuo para proteger la infraestructura crítica y los activos de información	personal en procedimientos de emergencia ante incendios

Conclusión

Realmente no se tiene nada de seguridad física, ya que algo tan simple como contar con cerraduras en la puertas donde está el servidor principal ya deja mucho que desear. Esto pues claramente afecta en la perspectiva del cliente, ya que se puede ver como algo que es seguro y que no se preocupan por la confidencialidad de los datos médicos que se almacenan. De igual manera no se cuida la parte de la integridad de los datos, ya que por ejemplo, alguien puede acceder al servidor principal y alterar la información, pero si no también tiene la opción de ver cuando haya alguna pausa y acceder a los datos desde la computadora de un colaborador, esto si se quiere alterar, pero si se quisiera borrar la información también se puede hacer de esa manera y al no contar con copias de seguridad la empresa se vería demasiado afectada, ya que perderían todos los datos médicos y no tendrían como recuperarlos. Entonces en esta empresa no es ni necesario crear algún tipo payload o malware, si no que gracias a los descuidos que tienen es tan sencillo como esperar alguna pausa y robarse una computadora por ejemplo y acceder al sistema.